

Financial Spoofing Campaign → Mailgun Rotation → Detection Rule Tuning

Sanitized one-page case study | Defender for Office 365 + KQL | May 2026

Context

A recurring financial spoofing campaign repeatedly targeted users using rotating sender domains, Mailgun infrastructure, and fake financial-company landing pages. Many emails bypassed detection and were delivered with ThreatType=None.

Goal

- Determine whether rotating domains belonged to the same campaign.
- Identify stable indicators suitable for operational detection.
- Reduce phishing delivery without causing large-scale false positives.

Key Actions

- Expanded an initial 253-email cluster into a larger infrastructure-level investigation.
- Identified recurring sender formats using Mailgun infrastructure.
- Correlated spoofed finance domains and shared landing-page behavior.
- Compared IP-based, sender-based, and URL-based detection approaches.
- Identified the shared URL prefix 'https://napp.' as the strongest recurring indicator.

Results (sanitized)

- Expanded investigation to 1,500+ related emails across 7 days.
- Detected strong overlap across rotating sender infrastructure.
- Validated near-100% malicious correlation using shared URL behavior.
- Supported sender/domain blocking recommendations implemented operationally.

KQL (short excerpt)

EmailUrlInfo | where Url contains '://napp' | join EmailEvents on NetworkMessageId

What this shows

I can move beyond single-email phishing analysis into infrastructure-level campaign correlation, balancing operational blocking decisions with false positive awareness.